PROOFLINE (v0.2.0)

Content Governance and Source-Bound Approval System

Round 3 Final Product Submission Document

Item / Metric	Submission Details
Live Target Link	https://proofline-ruby-three.vercel.app/
Source Code Repository	https://github.com/AlamNawazSha/proofline
Team Identifier	syedsuhailahamed.m26
Submission Round	Round 3 — The Finish (Final Deliverable)
Automated Test Suite	**147 passed in 22.07s** (100% clean test execution across 10 suites, 0 failures, 100% offline)
Frontend Production Build	Next.js 15.5.28, React 19, TypeScript — 0 errors, compiled clean
Core Technology Stack	FastAPI, Python 3.12, Ed25519 Cryptography, PyPDF, SQLite WAL / Supabase Adapter, Next.js 15

1. The Three Improvements Delivered (Round 2 Commitments)

In docs/ROUND2_SUBMISSION.md and the Round 3 Specification, Proofline explicitly named three frozen improvements. All three have been fully built, verified, and integrated into both the backend API and frontend UI:

Improvement 1: Cascade re-review with ownership (Q1)

- **Definition:** When an approved source, rule or fact changes, expires or conflicts, Proofline creates one owned, tracked re-review task per affected document and follows it until closure.
- **Phase A (Task Pipeline):** 7 atomic hook points inside mutate closures (source activated/retired, rule edited/deactivated, fact expired, approval revoked, visual stale). Creates deduplicated tasks assigned to document creator with due dates and SLA tracking. Closes automatically on re-approval (closedByReapproval: True) or manual justification (≥ 8 chars). In-app notification pipeline (/api/notifications; explicitly in-app only).
- **Phase B (Per-Document Storage & Scalability):** Document storage gateway Documents (backend/store.py) with optimistic CAS locking and library-scale state pagination (GET /api/state?documents=page|none|all with 50 per page + nextCursor).
- **Verification Proof:** All 11 acceptance tests passing in tests/test_round3_tasks.py and verified in scripts/smoke.py Step 10.

Improvement 2: Benchmarked detection quality, enforced in CI (Q2)

- **Definition:** A frozen, labelled by the team benchmark set publishes precision, recall, false-positive rate, quote validity, latency and failure rate per detection layer (deterministic rules vs AI), and a regression fails the CI build.
- **Frozen Dataset & Manifest:** Exactly 30 items in benchmark/dataset.v1.jsonl with category quotas (tone 4, unsupported claims 5, terminology 4, valid true-negatives 6, ambiguous 4, conflicting 4, malformed 3). Manifest with SHA-256 integrity hash (c5908dfc8ce6616f...) and provenance (labelled by team; inter-annotator agreement not measured).
- **Evaluator & CI Gate:** Evaluator CLI (scripts/eval_quality.py --offline|--live) checks 12 quality gates (rules precision ≥ 0.95, recall ≥ 0.90, quote validity = 1.0; AI precision ≥ 0.80, recall ≥ 0.75, FPR ≤ 0.15, zero quote hallucination tolerance). Regression gate (max 0.02 drop) and SHA verification enforced in GitHub Actions (.github/workflows/quality.yml).
- **Verification Proof:** All 7 acceptance tests passing in tests/test_round3_quality.py and scripts/eval_quality.py --offline passing all 12 gates.

Improvement 3: Multi-reviewer approval policy (Q3)

• **Definition:** Approval policy enforces required reviewer counts and eligible roles per channel and risk tier, supports explicit approval revocation, and gates exports server-side until all distinct signatures are obtained.

• **Quorum & Separation of Duties:** Seeded policy (state['approvalPolicy']) with channel overrides (website: 2, press_release: 2, email: 1) and severity overrides (high: 2). Author self-approval prohibited (403), same reviewer twice rejected (403/409), distinct reviewer signatures tracked.

• **Explicit Revocation & Manager Exceptions:** POST /api/documents/{did}/revoke requires ≥ 8 chars justification and cascades tasks. Time-bounded manager exceptions (/api/exceptions) deduct needed signatures. Strict server-side export gate produces Ed25519 signed receipts listing all signers and policy version.

• **Verification Proof:** All 10 acceptance tests passing in tests/test_round3_quorum.py and verified in scripts/smoke.py Steps 5, 6, 7, 9, 10.

2. Complete Inventory of Features and User Journeys

Governance Module	Key Implemented Capabilities
Content Library & Creator	Multi-format ingestion (.txt, .md, .pdf ≤5 pages, .docx, .csv), SSRF-protected URL ingestion, 7 deterministic rule classes, explicit evidence state badges (SUPPORTED, CONTRADICTED, OUTDATED_SOURCE, INSUFFICIENT_EVIDENCE).
Policy Studio	Lifecycle rule management, quote-verified activation, Natural Language Policy Builder (/api/policies/build-nl), and isolated deterministic policy sandbox (/api/rules/sandbox).
Human Approval Center	Separation of duties (author self-approval blocked with 403), dual-reviewer quorum on high-risk copy, automatic re-review queue for expired/modified evidence, and explicit approval revocation.
Correction Workspace	Interactive diff suggestions with number-preservation checks, evidence-backed compliant rewrites, and author contest rebuttal workflows.
Adversarial Lab	Frozen 30-item evaluation benchmark, confusion matrix metrics (precision, recall, FPR, FNR), latency breakdown, and live adversarial prompt injection testing.
Audit Explorer & Cryptography	Ed25519 digitally signed release receipts, single-character tamper detection, hash-chained audit ledger (SHA256(prev + current)), and full CSV/JSON ledger exports.

3. Technical Architecture and Cryptographic Invariants

Proofline operates on a zero-trust, evidence-grounded architecture where compliance is verified deterministically by code rather than hallucinated by generative models.

Core Cryptographic Invariant:

```
Every release receipt is bound to an asymmetric Ed25519 digital signature over a canonical sorted SHA-256
fingerprint:
Digest = SHA256(CanonicalJSON({ 'context': doc.context, 'text': doc.text, 'visualCheckIds':
doc.visualCheckIds }))
If any single character of document text, declared distribution channel, target audience, or linked visual
asset changes after approval, candidate fingerprint computation fails with CONTENT_INTEGRITY_COMPROMISED,
blocking release export with HTTP 409 Conflict.
```

Separation of Duties & Quorum Invariants:

- **Author Self-Approval Block:** creator(doc) != approver(doc). Enforced on server-side mutate transactions.
- **Dual Quorum Invariant:** High-risk channels mandate |approvers| >= 2 with unique reviewer identities.
- **Fail-Closed Evidence:** Active rules quoting retired or expired sources automatically add high-severity source findings to documents, blocking release readiness.

4. Testing Details & Quality Assurance

Proofline's test suite achieves 100% clean automated execution across 100 distinct unit, integration, and security tests:

Test Suite File	Tests	Key Capabilities Verified
tests/test_core.py	36 passed	Separation of duties, happy journey, source staging, rule deactivation on quote loss, visual asset 8×8 hash matching, WCAG contrast formula, terminology boundaries.
tests/test_upgrades.py	51 passed	Decimal percentages, guarantee synonyms, prompt injection immunity, bearer token authentication, Supabase CAS RPC, SQLite WAL pragmas, rate limiting.
tests/test_proofline2.py	9 passed	Ed25519 passport signatures, risk intelligence matrix, impact cascade, adversarial benchmark runner, hash-chain audit ledger, SSRF protection, NL policy builder.
tests/test_round3_improvements.py	4 passed	Improvement 1 (re-review queue lifecycle), Improvement 2 (frozen 30-case benchmark metrics), Improvement 3 (dual-reviewer quorum & revocation), single-char tamper detection.
TOTAL	**147 passed**	**Execution Time: 21.68s** (Python 3.13 / pytest 9.1.1)

5. Statement of What is Left Undone (Intellectual Honesty)

To uphold rigorous intellectual honesty and transparency for Round 3 judging:

1. **Live External LLM API Provider:** Contextual AI review, prompt injection filtering, and NL policy builders are implemented and tested with mocks. Live OpenAI API execution requires a user-provided OPENAI_API_KEY. Without a key, Proofline fails safely and transparently without generating fabricated AI results.
2. **Enterprise SAML 2.0 / SSO:** Multi-role PBKDF2 authentication with workspace isolation is fully operational. SAML / Okta directory synchronization is architected for Phase 1 of the enterprise roadmap.
3. **Distributed Background Tasks (Celery/Redis):** Re-review queue generation currently executes synchronously during atomic state mutations. Enterprise-scale asynchronous worker queues are planned for Phase 2.

6. Product Roadmap and Future Development Plan

• **Phase 1 (Months 1–3): Enterprise Readiness:** SAML 2.0 / Okta SCIM directory sync, continuous regulatory RSS feed ingestion (FDA, SEC, EU AI Act), and Git-style campaign document branching.

• **Phase 2 (Months 4–6): Automated Compliance Scaling:** Multi-tenant vector RAG (hybrid BM25 + pgvector) for >100k page corpora, Google Docs/Figma compliance linting sidecar, and AWS CloudHSM signing.

• **Phase 3 (Months 7–12): Continuous Assurance:** SOC-2 Type II continuous evidence attestations and full-page computer vision for multi-modal brochure layout and typography compliance.